
Cyberboswachters

De beste digitale stropers zijn ook de beste cyberboswachters

Dams Tim



Authenticatie

Bewijzen wie je bent om toegang te krijgen tot een website of applicatie heet **authenticatie**. Vervolgens, afhankelijk van wie je bent, zal je bepaalde rechten toegewezen krijgen die bepalen wat je wel en niet kunt doen op de website of applicatie, dit heet **authorizatie**. In dit hoofdstuk gaan we ons toespitsen op het eerste deel van dit proces: de authenticatie. Hierbij gaan we vooral kijken hoe we op een veilige manier moeten omgaan als web-of applicatiebeheerders met de login-informatie van gebruikers.

We weten al dat je geheime sleutel een belangrijk onderdeel is in heel veel aspecten van cybersecurity. Het **weten van de geheime sleutel** is een eerste vorm van authenticatie (maar uiteraard niet de beste). Je logingegevens die je gebruikt om toegang te krijgen tot een website bestaan in primaire vorm meestal uit een combinatie van gebruikersnaam en paswoord. Het paswoord in dit verhaal is kortom gewoon een ander woord voor je geheime sleutel. Als beheerder is het dan ook essentieel dat we uitermate veilig omgaan met de paswoorden van gebruiker. We zouden niet willen dat alle login gegevens van onze gebruikers in verkeerde handen vallen.

Veilige paswoorden

Ongeacht de veiligheden die we inbouwen als cyberboswachter, veel blijft afhangen van de manier waarop eindgebruikers omgaan met hun paswoorden. Volgende regels worden continue **niét** gehanteerd, met alle gevolgen van dien:

- Hergebruik nooit een wachtwoord. In principe heb je één wachtwoord *pér* service (applicatie, website, etc.).
- Gebruik geen wachtwoorden die in *dictionaries* staan. Maar overweeg volledig random gegenereerde wachtwoorden.
- Zorg ervoor dat je wachtwoorden lang genoeg zijn (minimum 12 tekens).
- Zorg ervoor dat je wachtwoorden steeds een combinatie van cijfers, letters (grote én kleine) en leestekens zijn.

Trouwens, herinner je de McCumber kubus waarin we benadrukten dat technologie maar één aspect is om C.I.A. toe te passen op je data in z'n 3 primaire vormen? Het zal je niet verbazen dat cybercriminelen

niet altijd gaan proberen databanken aan te vallen om paswoorden van gebruikers te pakken te krijgen. Als zij een specifiek doelwit hebben dan gaan we vaak op andere manieren te werk:

- **Password spraying:** hierbij gaat de hacker een (beperkte) lijst van veelgebruikte paswoorden testen op een grote groep *useraccounts* van een bepaalde website, in de hoop een *hit* te hebben (*"spray and pray"*).
- **(Spear) phishing:** bij phishing hanteert de aanvaller de goedgelovigheid of onoplettendheid van de gebruiker om een ogenschijnlijk betrouwbare mail of bericht te sturen met daarin een link naar een pagina die malware installeert of een fake login scherm toont. Bij spear phishing gebruikt de aanvaller geen massmail, maar gaat hij juist gericht één specifiek doelwit een op maat gemaakte mail of bericht sturen. Spear phishing is heden ten dage een van dé **social engineeringen** aanvallen bij uitstek.
- **Key loggers:** als de aanvaller toegang heeft tot de computer (wat uiteraard van over het netwerk kan) dan kan hij een permanente key logger installeren die continue alle toetsaanslagen op het systeem opneemt. Nadien kan de aanvaller deze logs dan analyseren in de hoop zo ook het paswoord of andere gevoelige informatie terug te vinden.

Hoe paswoorden opslaan

Hoe moet je nu als cyberboswachter de login-informatie van je gebruikers bewaren? We gaan een soort *bottom-up* aanpak hanteren, waarbij we beginnen met de meest naïeve oplossing en telkens verbeteringen zullen aanbrengen.

Paswoorden als plaintext bewaren

In het prille begin van het internet gebeurde dit quasi overal: de login-databank had 2 kolommen:

1. gebruikersnaam
2. gebruikerspaswoord

De paswoorden in kolom 2 stonden er zoals ze waren. Als een gebruiker wilde inloggen op dit soort websites dan moest hij z'n paswoord verzenden en dan ging de *backend* controleren of het ingezonden paswoord overeen kwam met het paswoord in de database. Het spreekt voor zich dat dit soort databanken van gigantische waarden zijn voor aanvallers: van zodra ze de databank hebben te pakken hebben ze alle paswoorden van alle gebruikers! Profit!

Paswoorden mogen nooit in leesbare vorm in een databank staan! Wanneer dit wel zo is dan kan je beter ogenblikkelijk je account bij die service deleten. Want alhoewel deze aanpak al lang bestaat

en al bijna even lang van geweten is dat deze erg onveilig is, toch zijn er nog steeds ontelbare websites en applicaties die hieraan zondigen.

Een goede manier om te weten of een service op deze manier werkt is gebruik maken van de “*Ik ben m’n wachtwoord vergeten*”-knop. Als je deze knop gebruikt en je krijgt een email met daarin jouw originele paswoord, dan kan je er zeker van zijn dat de service jouw paswoord op deze manier bewaard. In principe zou een service NOOIT jouw wachtwoord moeten kunnen zien. We gaan zelfs zien dat **jouw wachtwoord nooit je computer mag verlaten**, laat staan dat deze beschikbaar is in een plaintext database.

Dankwoord

Een oprechte dank aan Stefaan Somerling (RealDolmen) voor de feedback op het hoofdstuk omtrent GDPR. Geef gerust een sein als u, conform de GDPR wetgeving, liever uw naam niet in dit document ziet staan ;)

